



IT-Grundschutz

Einführung in den Grundschutz

1. IT-Grundschutz-Tag 2025 – 04.02.2025

Stefan Schuck– Referat TR, IT-GS Zertifizierung

Einstieg und Motivation





Informationssicherheit

- Informationssicherheit hat den Schutz von Informationen als Ziel
- Grundwerte der Informationssicherheit sind dabei u.a. die **Verfügbarkeit, Vertraulichkeit und Integrität** von Informationen
- Informationen können dabei auf Papier, in IT-Systemen oder auch in Köpfen gespeichert sein

Informationssicherheit liefert mehr als reine IT-Sicherheit



Informationssicherheit

...ist kein Produkt!

- Sicherheit kann man nicht kaufen
- Sicherheit muss man schaffen
- Natürlich kann man dazu auch auf vorhandene Produkte zurückgreifen

...ist kein Projekt!

- Es genügt nicht, Sicherheit einmal zu schaffen
- Sicherheit muss aufrechterhalten werden

... ist ein Prozess und Chefsache!

Informationssicherheit



Wir haben doch schon was getan! Wirksamkeit? Angemessenheit?



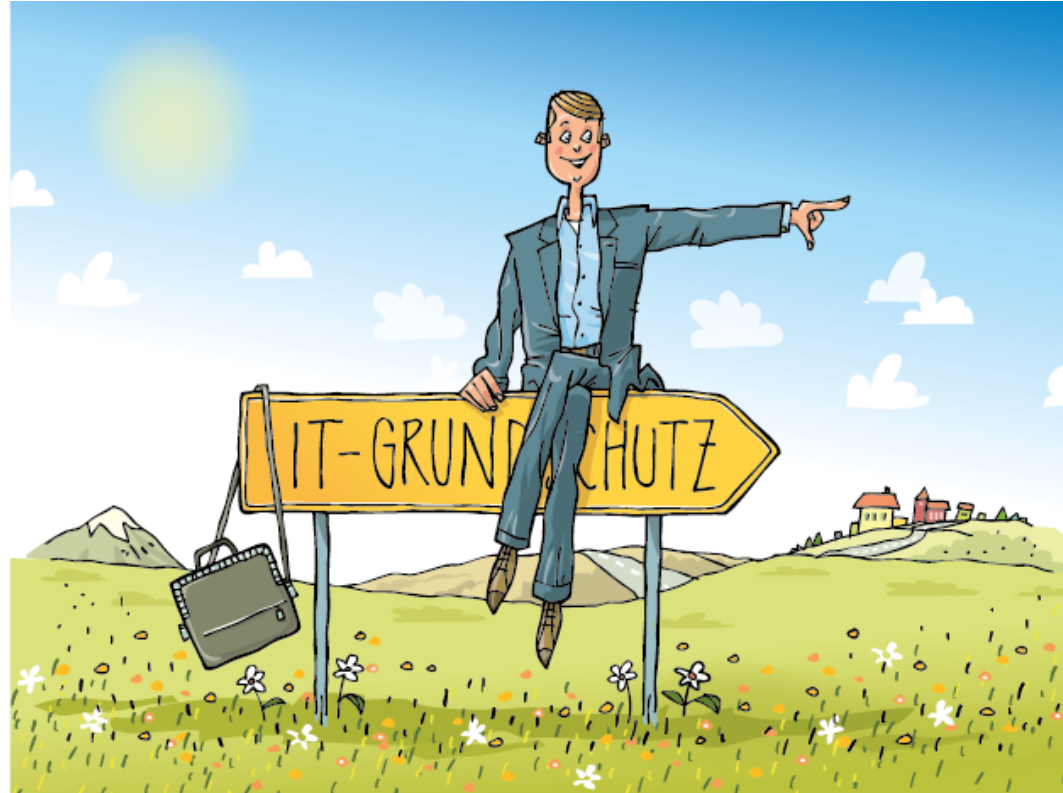


Informationssicherheit etablieren

- Zur Schaffung von Informationssicherheit ist es nicht ausreichend, einmalig ein **statisches** Sicherheitskonzept zu erstellen
- Statische Sicherheitskonzepte können durch das **dynamische Umfeld** mit sich ständig verändernder Bedrohungslage, neuen Angriffsvektoren usw. eine **andauernde Informationssicherheit** nicht wirksam gewährleisten
- Der Schlüssel zu einem **angemessenen Schutz** von Geschäftsprozessen/Informationen ist ein **systematisches Vorgehen** → Etablierung eines **Managementsystems für Informationssicherheit (ISMS)**
- ISMS bezeichnet die Planungs-, Lenkungs- und Kontrollaufgabe zu Aufbau, Aufrechterhaltung und kontinuierlicher Verbesserung eines durchdachten und wirksamen **Sicherheitsprozesses**

Viele Wege führen zu einen ISMS

...welcher Weg ist
der effektivste?





Managementsystem für Informationssicherheit (ISMS)



- Ein ISMS beinhaltet diverse Aspekte, die in der **IT-Grundschutz-Methodik** berücksichtigt werden
- Die **BSI-Standards** und das **IT-Grundschutz-Kompendium** bilden die Hauptwerke im IT-Grundschutz

BSI-Standards



- Die **BSI-Standards** 200-1 bis 200-3 erläutern, wie ein ISMS in einer Institution aufgebaut werden kann und die in den Geschäftsprozesse bzw. Fachaufgaben verarbeiteten Informationen abgesichert werden können
- In Kombination mit dem IT-Grundschutz-Kompendium angewandt, bilden diese beiden Komponenten des IT-Grundschutzes die **Grundlage für eine solide Informationssicherheit**



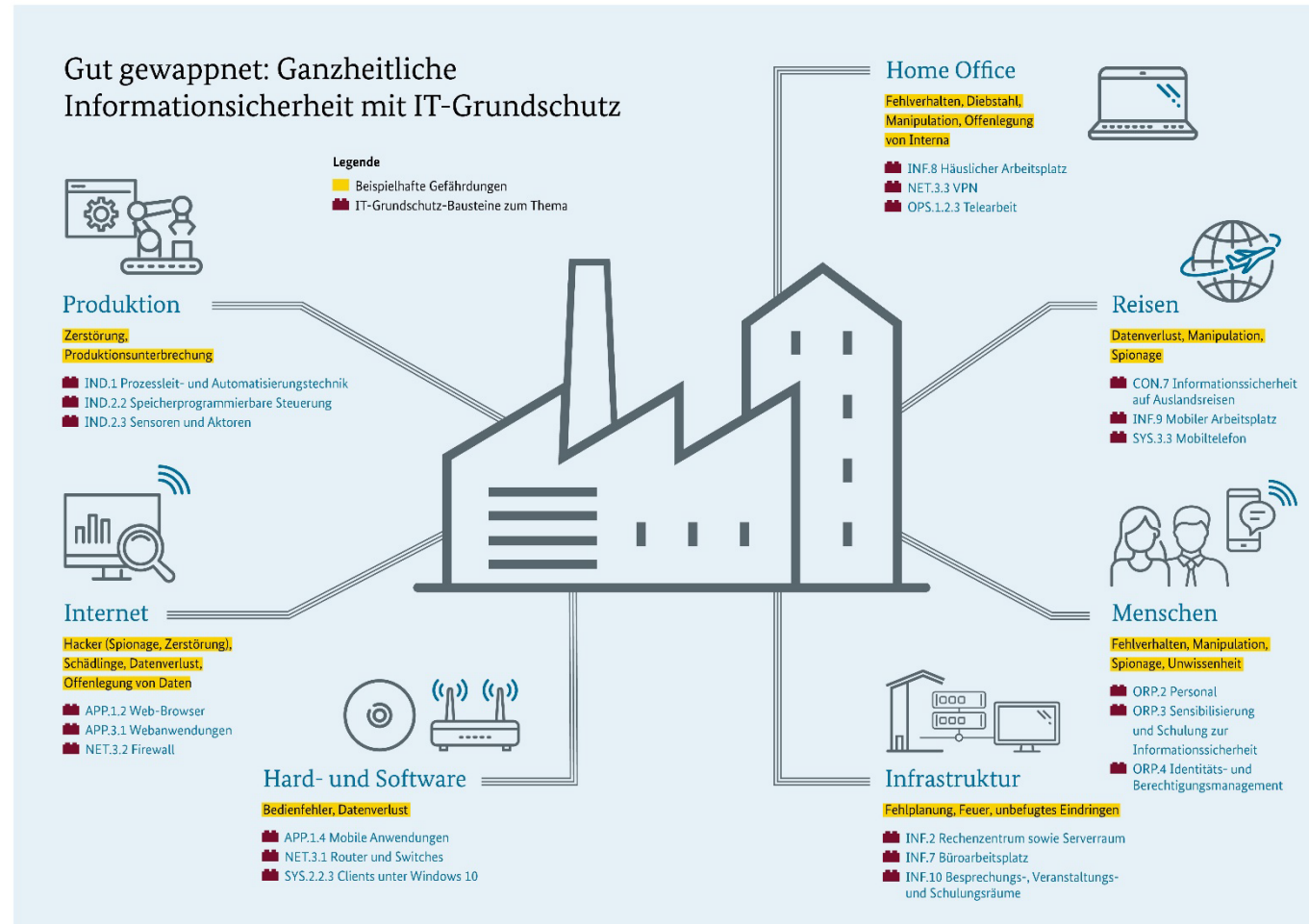


IT-Grundschutz-Kompodium

- Im **IT-Grundschutz-Kompodium** beschreiben Fachtexte, die sogenannten IT-Grundschutz-Bausteine, was ein Anwender tun muss, um einen bestimmten Bereich abzusichern
- Dabei wird ein ganzheitlicher Ansatz verfolgt: Infrastrukturelle, organisatorische, personelle und technische Standard-Sicherheitsanforderungen helfen, ein **Standard-Sicherheitsniveau** aufzubauen, um geschäftsrelevante Informationen zu schützen
- An vielen Stellen werden bereits höherwertige Sicherheitsanforderungen geliefert, die die Basis für sensiblere Bereiche sind



Ganzheitliche Informationssicherheit



Effiziente Vorgehensweise



- Klassische Vorgehensweisen für den Aufbau eines ISMS, z. B. ISO 27001, führen zu Beginn für den gesamten Geltungsbereich umfangreiche und zeitintensive **Risikoanalysen** durch
- Risiken werden ermittelt und Eintrittswahrscheinlichkeiten/Schadenauswirkungen abgeschätzt, um daraus angemessene **Sicherheitsmaßnahmen** zu **erarbeiten**
- Mit IT-Grundschutz **entfällt** bei normalem Schutzbedarf und typischen Einsatzszenarien der **Aufwand** für die Risikoanalysen und Erarbeitung von Sicherheitsanforderungen bzw. Sicherheitsmaßnahmen
- Der Vorteil für die Anwender ist ein deutlich reduzierter Aufwand, da direkt mit der **Umsetzung der Anforderungen** aus dem IT-Grundschutz-Kompendium begonnen werden kann



Verlässlicher Indikator für Informationssicherheit

- Ein ISMS nach ISO 27001 erfüllt die **selbst** von der Institution **gesetzten Sicherheitsziele**, es wird **kein** definiertes **Sicherheitsniveau vorgegeben**
- Durch weniger konkrete Vorgaben besteht mehr Spielraum bei der Implementierung bis hin zur Akzeptanz von Risiken und zum Auslassen der Umsetzung von Maßnahmen (Controls Annex A), somit ist eine **Vergleichbarkeit** zwischen ISO 27001 Umsetzungen nur **schwer gegeben**
- IT-Grundschutz gibt ein **konkret definiertes Sicherheitsniveau** vor, das **nicht unterschritten** werden darf
- Dadurch ist eine **Vergleichbarkeit** gegeben, die als **verlässlicher Indikator** bei der Kooperation verschiedener Institutionen dient

Das IT-Grundschutz-Kompendium und die BSI-Standards



IT-Grundschutz-Kompodium Edition 2023

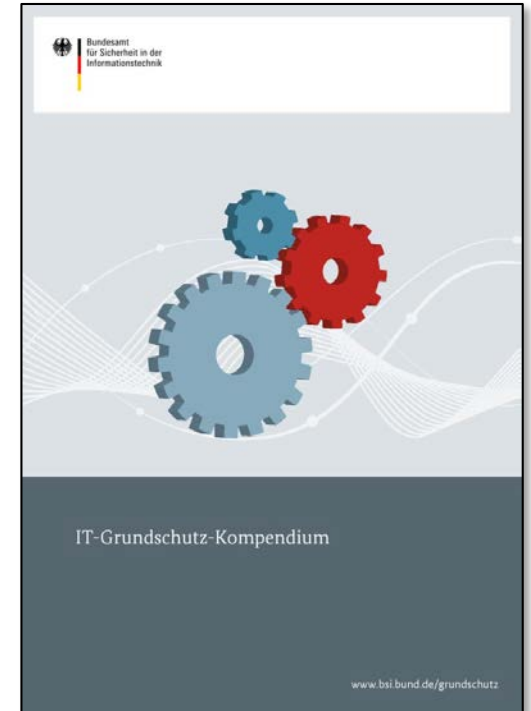


Bausteine

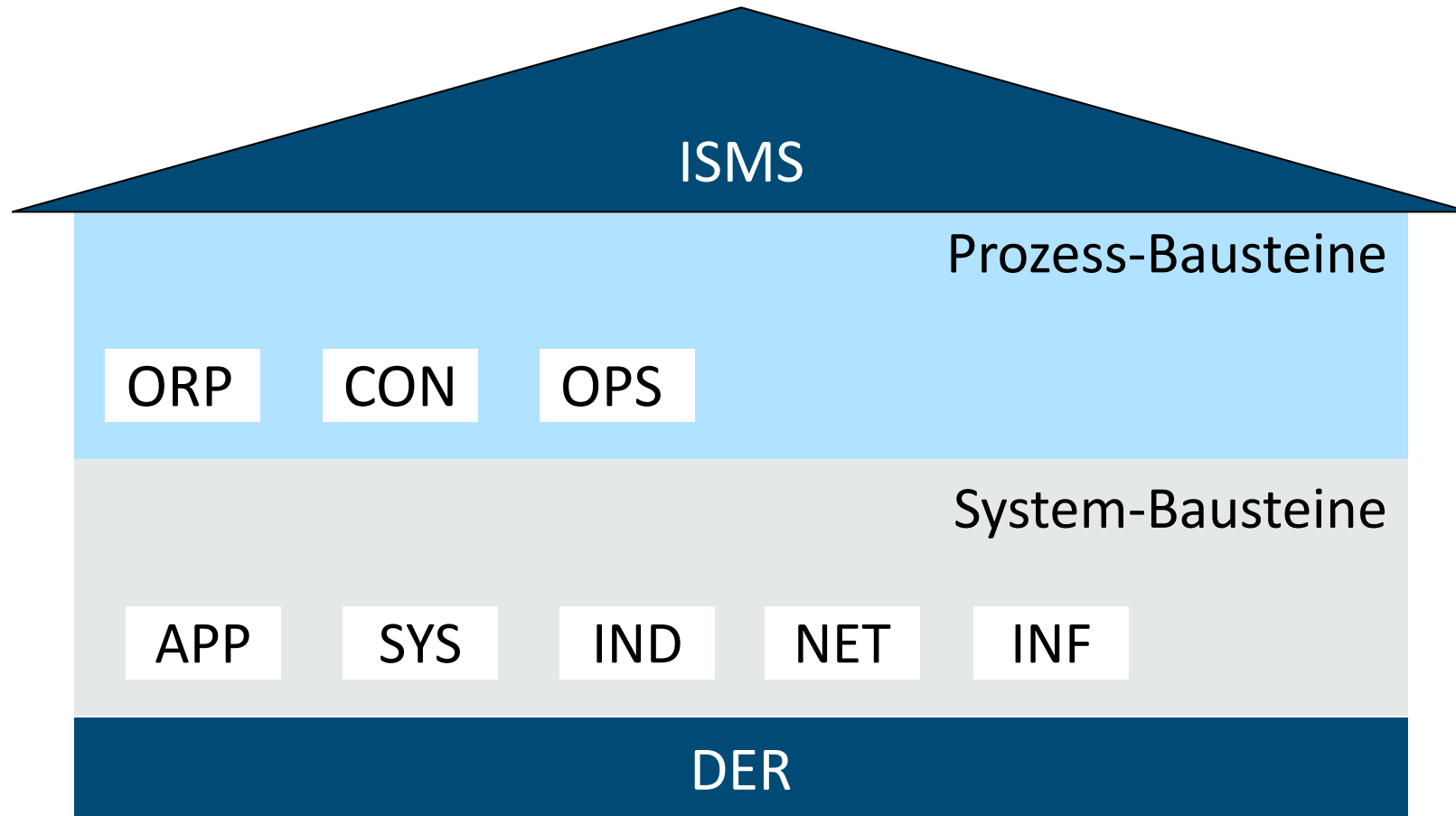
- 111 Bausteine
- Online in verschiedenen Formaten
- Druckversion bei Reguvis/Bundesanzeiger Verlag bestellbar

Umsetzungshinweise

- ca. 50 Umsetzungshinweise
- Community Drafts
- Online verfügbar



Struktur des IT-Grundschutz-Kompendiums





Auszug von Schichten und Bausteinen

ISMS: Sicherheitsmanagement

- ↓ [ISMS.1 Sicherheitsmanagement](#)

ORP: Organisation und Personal

- ↓ [ORP.1 Organisation](#)
- ↓ [ORP.2 Personal](#)
- ↓ [ORP.3 Sensibilisierung und Schulung zur Informationssicherheit](#)
- ↓ [ORP.4 Identitäts- und Berechtigungsmanagement](#)
- ↓ [ORP.5 Compliance Management \(Anforderungsmanagement\)](#)

CON: Konzeption und Vorgehensweise

- ↓ [CON.1 Kryptokonzept](#)
- ↓ [CON.2 Datenschutz](#)
- ↓ [CON.3 Datensicherungskonzept](#)
- ↓ [CON.6 Löschen und Vernichten](#)
- ↓ [CON.7 Informationssicherheit auf Auslandsreisen](#)
- ↓ [CON.8 Software-Entwicklung](#)
- ↓ [CON.9 Informationsaustausch](#)
- ↓ [CON.10 Entwicklung von Webanwendungen](#)

NET: Netze und Kommunikation

- ↓ [NET.1.1 Netzarchitektur und -design](#)
- ↓ [NET.1.2 Netzmanagement](#)
- ↓ [NET.2.1 WLAN-Betrieb](#)
- ↓ [NET.2.2 WLAN-Nutzung](#)
- ↓ [NET.3.1 Router und Switches](#)
- ↓ [NET.3.2 Firewall](#)
- ↓ [NET.3.3 VPN](#)
- ↓ [NET.4.1 TK-Anlagen](#)
- ↓ [NET.4.2 VoIP](#)
- ↓ [NET.4.3 Faxgeräte und Faxserver](#)

INF: Infrastruktur

- ↓ [INF.1 Allgemeines Gebäude](#)
- ↓ [INF.2 Rechenzentrum sowie Serverraum](#)
- ↓ [INF.5 Raum sowie Schrank für technische Infrastruktur](#)
- ↓ [INF.6 Datenträgerarchiv](#)
- ↓ [INF.7 Büroarbeitsplatz](#)
- ↓ [INF.8 Häuslicher Arbeitsplatz](#)
- ↓ [INF.9 Mobiler Arbeitsplatz](#)
- ↓ [INF.10 Besprechungs-, Veranstaltungs- und Schulungsraum](#)
- ↓ [INF.11 Allgemeines Fahrzeug](#)
- ↓ [INF.12 Verkabelung](#)
- ↓ [INF.13 Technisches Gebäudemanagement](#)

IND: Industrielle IT

- ↓ [IND.1 Prozessleit- und Automatisierungstechnik](#)
- ↓ [IND.2.1 Allgemeine ICS-Komponente](#)
- ↓ [IND.2.2 Speicherprogrammierbare Steuerung \(SPS\)](#)
- ↓ [IND.2.3 Sensoren und Aktoren](#)
- ↓ [IND.2.4 Maschine](#)
- ↓ [IND.2.7 Safety Instrumented Systems](#)
- ↓ [IND.3.2 Fernwartung im industriellen Umfeld](#)

CON: Konzeption und Vorgehensweise

- ↓ [CON.1 Kryptokonzept](#)
- ↓ [CON.2 Datenschutz](#)
- ↓ [CON.3 Datensicherungskonzept](#)
- ↓ [CON.6 Löschen und Vernichten](#)
- ↓ [CON.7 Informationssicherheit auf Auslandsreisen](#)
- ↓ [CON.8 Software-Entwicklung](#)
- ↓ [CON.9 Informationsaustausch](#)
- ↓ [CON.10 Entwicklung von Webanwendungen](#)



Bausteine

- Umfang: ca. 10 Seiten!
- Bestehen aus Einleitung, Zielsetzung, Abgrenzung und Modellierung, spezifische Gefährdungslage und Anforderungen
- Die Anforderungen geben vor, was getan werden muss, um einen bestimmten Bereich abzusichern



Basis-Anforderungen



3.1. Basis-Anforderungen

Die folgenden Anforderungen **MÜSSEN** für diesen Baustein vorrangig erfüllt werden.

OPS.1.2.5.A1 Planung des Einsatzes der Fernwartung (B)

Der Einsatz der Fernwartung **MUSS** an die Institution angepasst werden. Die Fernwartung **MUSS** hinsichtlich technischer und organisatorischer Aspekte bedarfsgerecht geplant werden. Dabei **MUSS** mindestens berücksichtigt werden, welche IT-Systeme ferngewartet werden sollen und wer dafür zuständig ist.

OPS.1.2.5.A2 Sicherer Verbindungsaufbau bei der Fernwartung von Clients [Benutzer] (B)

Wird per Fernwartung auf Desktop-Umgebungen von Clients zugegriffen, **MUSS** der Benutzer des IT-Systems diesem Zugriff explizit zustimmen.

OPS.1.2.5.A3 Absicherung der Schnittstellen zur Fernwartung (B)

Die möglichen Zugänge und Kommunikationsverbindungen für die Fernwartung **MÜSSEN** auf das notwendige Maß beschränkt werden. Alle Fernwartungsverbindungen **MÜSSEN** nach dem Fernzugriff getrennt werden.



OPS.1.2.5 Fernwartung

1. Beschreibung

1.1. Einleitung

Mit dem Begriff Fernwartung wird ein Zugriff auf IT-Systeme und die darauf laufenden Anwendungen bezeichnet, der von einem anderen IT-System aus erfolgt. Der Zugriff kann z. B. dazu dienen, Konfigurations-, Wartungs- oder Reparaturarbeiten durchzuführen.

Die Fernwartung kann auf unterschiedliche Weise geschehen. Bei der Fernwartung von Clients werden oft die Tastatur- und Maussignale vom IT-System eines Administrators an ein entferntes IT-System übertragen. Das entfernte IT-System überträgt die Bildschirmausgabe an das IT-System des Administrators. Der Administrator führt Aktionen auf dem entfernten IT-System aus, als wenn er selbst vor Ort wäre (aktive Fernwartung). Bei der Fernwartung von Servern wird oft die Ein- und Ausgabe der Konsole übertragen.

Bei der passiven Fernwartung werden nur die Bildschirmhalte eines IT-Systems zum Administrator übertragen. Der Administrator erteilt einem Benutzer vor Ort Anweisungen, die von ihm ausgeführt und vom Administrator beobachtet werden. Allerdings erweist sich dieses Vorgehen in der Praxis meist als sehr zeitintensiv und umständlich, weshalb häufig dem IT-Betrieb voller Zugriff über das IT-System zugewiesen wird.

Da sich viele IT-Systeme außerhalb der Reichweite ihrer Administratoren befinden (z. B. in entfernten Rechenzentren, Industrieanlagen oder einem Außenstandort ohne IT-Personal), wird Fernwartung in vielen Institutionen eingesetzt. Bei der Fernwartung wird oft über unsichere Netze auf interne IT-Systeme und Anwendungen einer Institution zugegriffen. Wegen der dabei bestehenden tiefgreifenden Eingriffsmöglichkeiten in diese IT-Systeme und Anwendungen ist die Absicherung von Fernwartungskomponenten von besonderer Bedeutung.

1.2. Zielsetzung

Ziel dieses Bausteins ist der Schutz der Informationen, die bei der Fernwartung gespeichert, verarbeitet und übertragen werden sowie der Schutz der Fernwartungsschnittstellen von IT-Systemen. Zu diesem Zweck werden Anforderungen an die Fernwartung gestellt, die sich gleichermaßen auf Funktionen der aktiven und passiven Fernwartung beziehen.

Standard-Anforderungen



3.2. Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik für diesen Baustein. Sie SOLLTEN grundsätzlich erfüllt werden.

OPS.1.2.5.A5 Einsatz von Online-Diensten (S)

Die Institution SOLLTE festlegen, unter welchen Umständen Online-Dienste zur Fernwartung genutzt werden dürfen, bei denen die Verbindung über einen externen Dienstleister hergestellt wird. Der Einsatz solcher Dienste SOLLTE generell auf möglichst wenige Fälle beschränkt werden. Die IT-Systeme SOLLTEN keine automatisierten Verbindungen zum Online-Dienst aufbauen. Es SOLLTE sichergestellt werden, dass der eingesetzte Online-Dienst die übertragenen Informationen Ende-zu-Ende-verschlüsselt.



OPS.1.2.5 Fernwartung

1. Beschreibung

1.1. Einleitung

Mit dem Begriff Fernwartung wird ein Zugriff auf IT-Systeme und die darauf laufenden Anwendungen bezeichnet, der von einem anderen IT-System aus erfolgt. Der Zugriff kann z. B. dazu dienen, Konfigurations-, Wartungs- oder Reparaturarbeiten durchzuführen.

Die Fernwartung kann auf unterschiedliche Weise geschehen. Bei der Fernwartung von Clients werden oft die Tastatur- und Maussignale vom IT-System eines Administrators an ein entferntes IT-System übertragen. Das entfernte IT-System überträgt die Bildschirmausgabe an das IT-System des Administrators. Der Administrator führt Aktionen auf dem entfernten IT-System aus, als wenn er selbst vor Ort wäre (aktive Fernwartung). Bei der Fernwartung von Servern wird oft die Ein- und Ausgabe der Konsole übertragen.

Bei der passiven Fernwartung werden nur die Bildschirmhalte eines IT-Systems zum Administrator übertragen. Der Administrator erteilt einem Benutzer vor Ort Anweisungen, die von ihm ausgeführt und vom Administrator beobachtet werden. Allerdings erweist sich dieses Vorgehen in der Praxis meist als sehr zeitintensiv und umständlich, weshalb häufig dem IT-Betrieb voller Zugriff über das IT-System zugewiesen wird.

Da sich viele IT-Systeme außerhalb der Reichweite ihrer Administratoren befinden (z. B. in entfernten Rechenzentren, Industrieanlagen oder einem Außenstandort ohne IT-Personal), wird Fernwartung in vielen Institutionen eingesetzt. Bei der Fernwartung wird oft über unsichere Netze auf interne IT-Systeme und Anwendungen einer Institution zugegriffen. Wegen der dabei bestehenden tiefgreifenden Eingriffsmöglichkeiten in diese IT-Systeme und Anwendungen ist die Absicherung von Fernwartungskomponenten von besonderer Bedeutung.

1.2. Zielsetzung

Ziel dieses Bausteins ist der Schutz der Informationen, die bei der Fernwartung gespeichert, verarbeitet und übertragen werden sowie der Schutz der Fernwartungsschnittstellen von IT-Systemen. Zu diesem Zweck werden Anforderungen an die Fernwartung gestellt, die sich gleichermaßen auf Funktionen der aktiven und passiven Fernwartung beziehen.

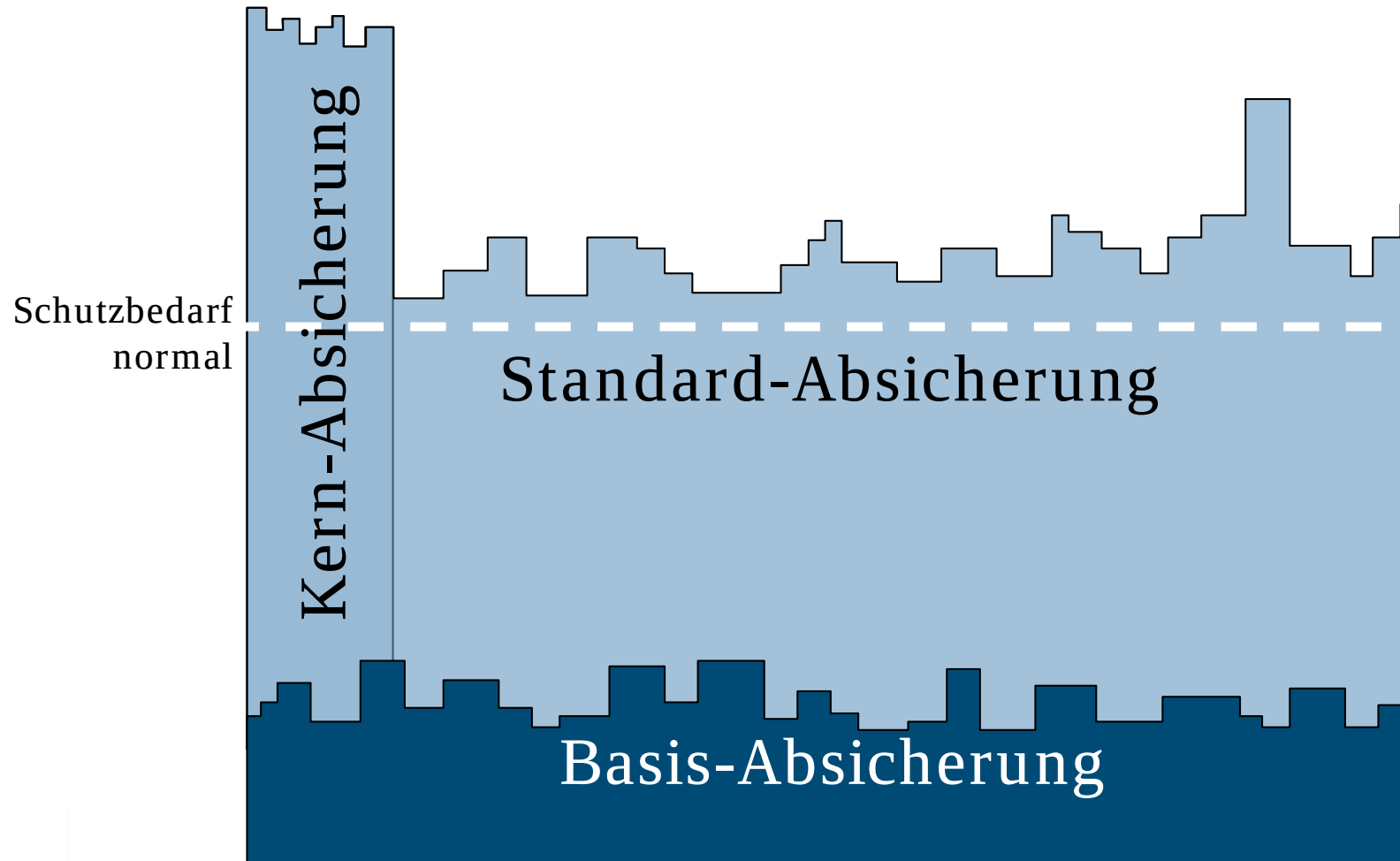
BSI-Standards – Methode und Anleitung



- Inhalt
 - 200-1: **Managementsysteme für Informationssicherheit**
 - 200-2: **IT-Grundschutz-Methodik**
 - 200-3: **Risikoanalyse auf der Basis von IT-Grundschutz**
 - 200-4: **Business Continuity Management**
- Verfügbare Versionen
 - Kostenlos als PDF auf BSI-Webseite
 - Kostenpflichtige gedruckte Version über Reguvis Fachmedien GmbH (ehemals Bundesanzeiger Verlag)

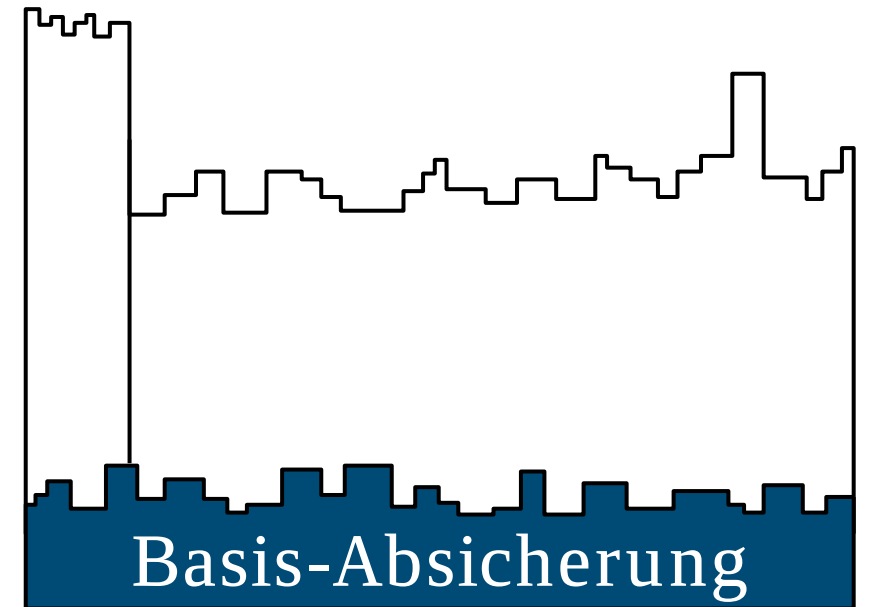


Überblick über die Vorgehensweisen



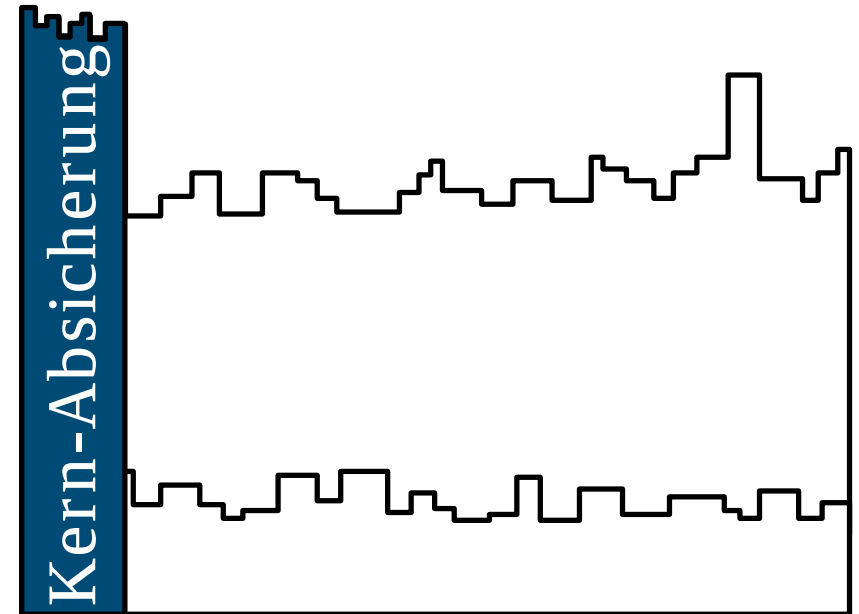
Basis-Absicherung

- **Vereinfachter Einstieg** in das Sicherheitsmanagement
- Grundlegende **Erstabsicherung** der Geschäftsprozesse und Ressourcen
 - Erstabsicherung in der Breite
 - Umsetzung essentieller Anforderungen
- Auf die Bedürfnisse von **KMUs** zugeschnitten
- Auch für **kleine Institutionen** geeignet



Kern-Absicherung

- Schutz herausragender, besonders gefährdeter Geschäftsprozesse und Ressourcen (**Kronjuwelen**)
- Unterschied zu IT-Grundschutz Classic: Fokussierung auf einen kleinen, aber **sehr wichtigen Informationsverbund**
- **Zeitersparnis** im Vorgehen
- **beschleunigte Absicherung** dieser Ressourcen in der Tiefe



Standard-Absicherung

- Implementierung eines **vollumfänglichen** Sicherheitsprozesses (kompatibel zur ISO 27001)
- Zertifizierbar **nach ISO 27001 auf der Basis von IT-Grundschutz**





Vorgehen nach IT-Grundschutz*

Strukturanalyse

Schutzbedarfsfeststellung

Modellierung

IT-Grundschutz-Check

Risikoanalyse

- Erfassung der Bestandteile des Informationsverbundes (Geltungsbereichs) ausgehend von **Geschäftsprozessen, Anwendungen, IT-Systemen/-Komponenten, Räumen und Gebäuden**
- Die einzelnen „Objekte“ werden **Zielobjekte** genannt
- Gruppierungen möglich

*Kern-/Standard-Absicherung, nur Teile bei Basis-Absicherung





Vorgehen nach IT-Grundschutz

Strukturanalyse

Schutzbedarfsfeststellung

Modellierung

IT-Grundschutz-Check

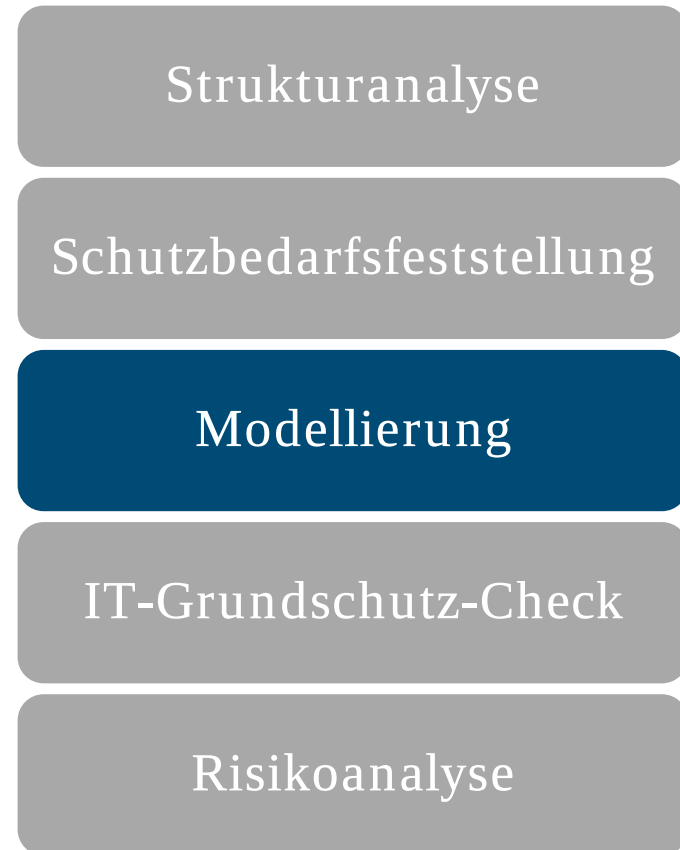
Risikoanalyse

- Bestimmung des **Schutzbedarfs** für alle Zielobjekte aus der Strukturanalyse bezüglich **Vertraulichkeit**, **Integrität** und **Verfügbarkeit**
- Der Schutzbedarf orientiert sich an den möglichen Schäden, die mit einer Beeinträchtigung der betroffenen Geschäftsprozesse und der damit verbundenen Anwendungen eintreten können
- Anschließend wird daraus der Schutzbedarf für alle weiteren Zielobjekte (z. B. IT-Systeme, Räume, Kommunikationsverbindungen) **abgeleitet**

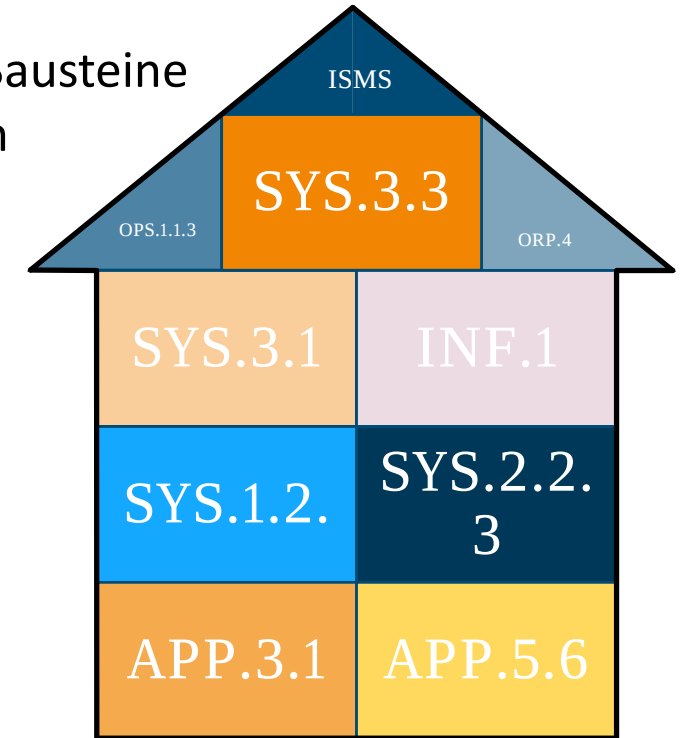
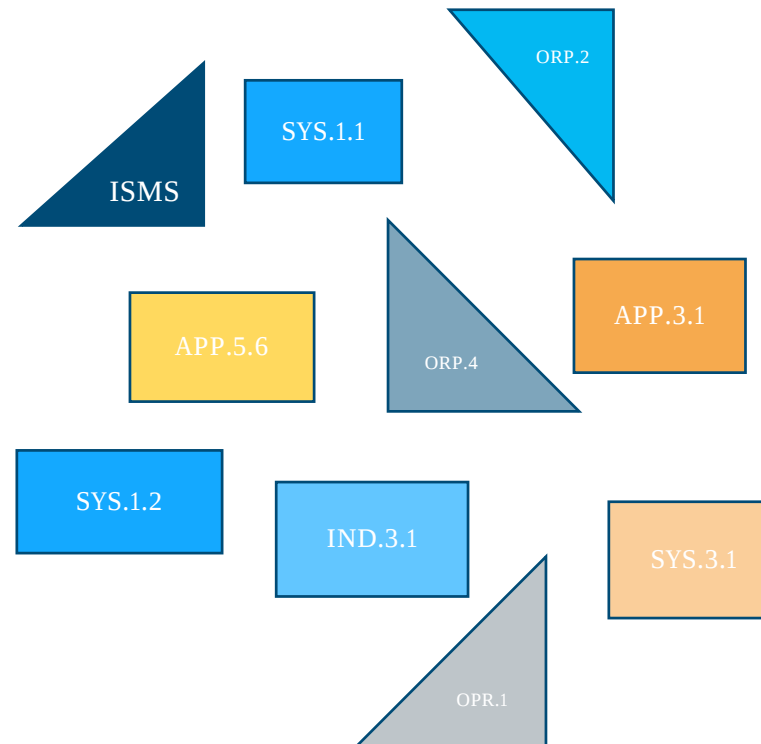




Vorgehen nach IT-Grundschutz



- **Nachbildung** (Modellierung) des Informationsverbundes mit Hilfe der Bausteine aus dem IT-Grundschutz-Kompendium





Vorgehen nach IT-Grundschutz

Strukturanalyse

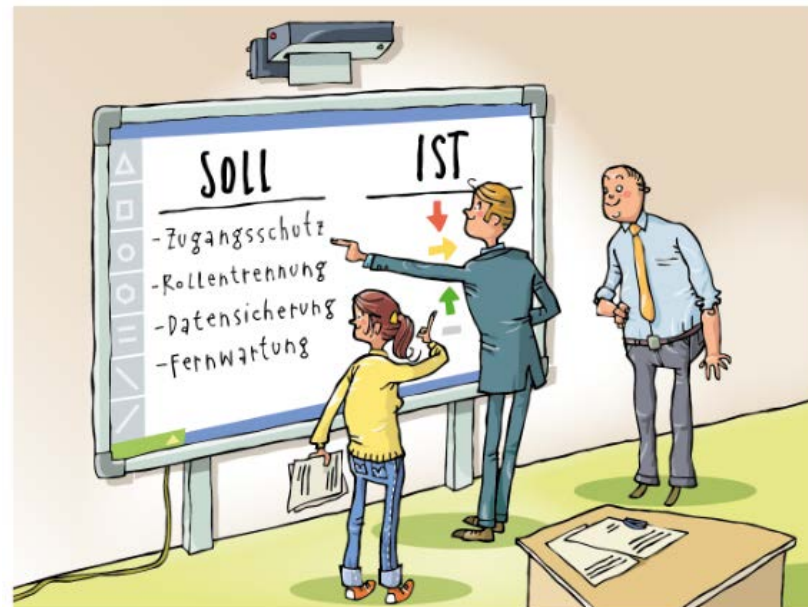
Schutzbedarfsfeststellung

Modellierung

IT-Grundschutz-Check

Risikoanalyse

- Soll/Ist-Vergleich
- Welche **Anforderungen** aus dem IT-Grundschutz-Kompendium sind bereits **umgesetzt** und welche müssen noch umgesetzt werden?





Vorgehen nach IT-Grundschutz

Strukturanalyse

Schutzbedarfsfeststellung

Modellierung

IT-Grundschutz-Check

Risikoanalyse

- Bei normalem Schutzbedarf und typischen Einsatzszenarien ist **keine** Risikoanalyse notwendig
- Bei
 - **hohem** oder **sehr hohem Schutzbedarf** oder
 - wenn **besondere Einsatzbedingungen** vorliegen oder
 - wenn **Komponenten** verwendet werden, die **nicht mit den existierenden Bausteinen** des IT-Grundschutz-Kompendiums **abgebildet** werden können

ist zu prüfen, ob sich zusätzliche Sicherheitsanforderungen ergeben und damit zusätzliche oder ersatzweise höherwertige Sicherheitsmaßnahmen erforderlich sind (**Risikoanalyse**)



Nachweis der Umsetzung von IT-Grundschutz

- Der **Nachweis** über die erfolgreiche Umsetzung von IT-Grundschutz durch einen **unabhängigen** BSI zertifizierten IT-Grundschutz Auditor kann die Bemühungen für die Informationssicherheit nach Innen oder Außen sichtbar zu machen (Kunden, Partner, Öffentlichkeit)
- Die Basis-Absicherung kann mit dem **Testat nach der Basis-Absicherung** nachgewiesen werden
- Die Standard- bzw. Kern-Absicherung kann mit der **ISO 27001 Zertifizierung auf der Basis von IT-Grundschutz** nachgewiesen werden





BSI-Qualifizierungskonzept für IT-Grundschützer

- Das BSI hat ein zweistufiges Schulungsangebot entwickelt, um die Ausbildung im Bereich IT-Grundschutz auf ein **einheitlich hohes Niveau** zu bringen
- Interessierte Personen können sich zunächst zum **IT-Grundschutz-Praktiker** und im nächsten Schritt zum **IT-Grundschutz-Berater** qualifizieren
- Mit dem Abschluss zum IT-Grundschutz-Berater ist eine gleichnamige **Personenzertifizierung** möglich
- Auf der Website des BSI gibt es eine Übersicht von **Fortbildungsinstituten**, die Schulungen zum IT-Grundschutz-Praktiker und -Berater anbieten
- Für das Themengebiet Business Continuity Management gibt es den **BCM-Praktiker**

IT-Grundschutz-Profile



Definition



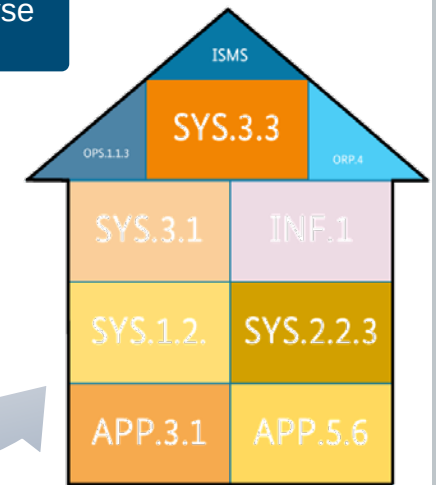
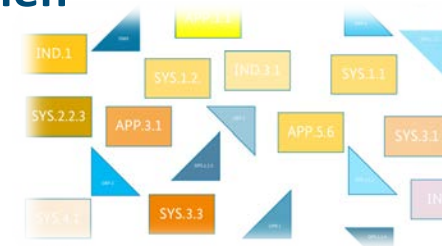
- Ein IT-Grundschutz-Profil ist ein **Muster-Sicherheitskonzept** für ein **ausgewähltes Szenario** (Verbund oder Prozess), es bereitet

– das Ergebnis mehrerer Prozessschritte der IT-Grundschutz-Vorgehensweise



und

- einer Auswahl **mehrerer Anforderungen der IT-Grundschutz-Bausteine**
- so auf, dass es als **Schablone** von **ähnlichen Institutionen** adaptiert werden kann!
- Vergleichbar mit einer „Dokumentenvorlage“



IT-Grundschutz-Profil zur Basis-Absicherung Kommunalverwaltung



- Um ein **erleichterten Einstieg** in die Informationssicherheit zu ermöglichen, hat eine Arbeitsgruppe aus Experten des deutschen Städtetag, Landkreistag und dem Städte- und Gemeindebund, in Zusammenarbeit mit dem BSI, ein **IT-Grundschutz-Profil** entwickelt
- Dies soll der Kommunalverwaltung und den kommunalen Gebietskörperschaften dabei helfen grobe **Schwachstellen aufzudecken**, zu beseitigen und möglichst schnell das Sicherheitsniveau in der Breite anzuheben.



IT-Grundschutz

Deutschland
Digital•Sicher•BSI

Vielen Dank für Ihre Aufmerksamkeit!

Stefan Schuck

grundschutz@bsi.bund.de

Bundesamt für Sicherheit in der Informationstechnik
Referat „BSI-Standards und IT-Grundschutz“
Godesberger Allee 185-189
53175 Bonn
www.bsi.bund.de



Bundesamt
für Sicherheit in der
Informationstechnik